

Connie HIPAA Compliance Statement

Functional Prototype · Version 1.1 · Effective 2025-10-14

Connie is committed to helping organizations deliver secure, HIPAA-compliant communications. This statement summarizes how Connie supports HIPAA compliance and outlines the shared responsibilities between Connie and organizations who have executed a Business Associate Agreement (BAA) with us. It supersedes any prior informal description of Connie's HIPAA posture.

WHERE CONNIE OPERATES TODAY

Connie's principal deployment is internal: Connie is owned by Nevada Senior Services (NSS), and NSS's use of Connie is intra-organizational rather than an external covered-entity / business-associate arrangement. The Connie BAA template described in this statement is for **future third-party organizations** adopting the platform under a SaaS arrangement. Compliance posture for the NSS deployment is governed by NSS's own policies and Connie's role as their internal communications platform.

SHARED RESPONSIBILITY

HIPAA compliance is a shared responsibility. Connie maintains administrative, physical, and technical safeguards across our infrastructure. Customer organizations are responsible for designing applications and workflows that use Connie's eligible features in a HIPAA-compliant manner, and for the workforce-training, sanctions, and minimum-necessary-access policies that govern their own staff. Where this statement marks an item as **Required**, customers must implement it; **Recommended** items strengthen security and are strongly encouraged.

For additional context, stakeholders may also reference the Connie data room (connie.one/dataroom), our Terms of Use, and our Acceptable Use Policy alongside this statement.

DESIGNATION OF HIPAA ACCOUNTS

Once a BAA is in place, organizations designate which Connie accounts and sub-accounts will handle Protected Health Information (PHI). Designated HIPAA accounts:

- May only process, store, or transmit PHI using HIPAA-eligible Connie features
- Are subject to a 15-minute inactivity auto-logout in the Connie Console

- Are exempt from certain content moderation, but remain subject to review for abuse signals

New sub-accounts created under a designated account inherit HIPAA designation automatically. New top-level accounts require a request to your Connie representative.

CUSTOMER REQUIREMENTS — ALL PRODUCTS

REQUIRED	RECOMMENDED
Encrypted communication: use HTTPS for all requests to and from Connie.	HTTP Basic or Digest authentication on your webhook endpoints.
Signed webhooks: verify Connie's cryptographic signatures on incoming requests.	Static IP allowlisting where available, to lock down inbound traffic.
No PHI in support tickets, email, or chat — use Connie resource IDs (Call SIDs, Message SIDs) instead.	Public/private key client validation for end-to-end request integrity.

HIPAA-ELIGIBLE CONNIE FEATURES

The following Connie capabilities can be used to build HIPAA-compliant workflows. Voice and messaging traffic must originate from and terminate to U.S. area codes.

- **Voice & SIP** — calling, IVR, and SIP trunking with TLS/SRTP encryption
- **SMS & MMS** — with HTTP Basic auth on media URLs and message redaction enabled
- **Conversations** — across SMS and in-app chat channels
- **Verify & Lookup** — via SMS and Voice (email channel is not eligible)
- **Video** — Group Rooms and recordings, with authenticated access to media
- **Studio, Functions & Debugger** — for designing, deploying, and monitoring eligible workflows
- **Event Streams** — where the destination sink is itself HIPAA-compliant

SPECIAL CONSIDERATIONS

- **Recordings:** encrypted at rest by default. Use HTTP Basic auth (or recording encryption with your public key) when retrieving media URLs.
- **Message Redaction:** enable both message-body and phone-number redaction for SMS workflows handling PHI.
- **Private Channels Only:** in chat workflows that may carry PHI, use private channels — never public.

- **Private Assets Only:** never store PHI in publicly accessible asset buckets or TwiML containers.
- **Third-Party Integrations:** customers are responsible for ensuring any external service that receives PHI is itself HIPAA-compliant and covered by an executed BAA.

SUBPROCESSORS & BAA CHAIN

Connie uses the following subprocessors that may, in their respective roles, process PHI:

SUBPROCESSOR	ROLE	BAA STATUS
Twilio	Voice, Messaging, Flex, Studio, TaskRouter, Functions, Conversations	Executed (HIPAA-eligible sub-accounts, paid HIPAA add-on)
Sinch	Fax channel ingest (where applicable)	In place
Mailgun	Outbound voicemail-notification email	Under audit / remediation
Auth0 (Okta)	Identity & SAML SSO (user identifiers; not call content)	Under audit / remediation
AWS S3 / CloudFront	Static asset hosting for branded surfaces	BAA audit / precondition required
PeoplePerson	Connie-affiliated CRM (case notes, contact records)	BAA audit / precondition required
TicketTack	Ticketing / case-tracking integration	BAA audit / precondition required
MyAdultDaycare	EMR integration (planned, in active development)	BAA precondition for production cutover

A current subprocessor list with status updates is maintained in the Connie data room and refreshed as remediation closes.

INTERNAL AUDIT & MONITORING

Connie operates an internal information-system-activity-review program consistent with 45 CFR §164.308(a)(1)(ii)(D), covering:

- Quarterly review of Auth0 user provisioning, Twilio Console access logs, and recording-store access events
- Vendor BAA refresh and subprocessor list update
- Periodic configuration drift check against the architecture rules documented in our internal runbooks (sub-account isolation, SAML attribute-mapping integrity, recording-encryption posture)

Audit findings are tracked internally and material findings inform updates to this statement.

BREACH NOTIFICATION

In the event of a breach of unsecured PHI as defined under §164.402, Connie commits to:

- Risk-of-compromise assessment using the four-factor test
- Written notification to affected customer organizations within sixty (60) days of discovery, per §164.410, including the standard breach details (description, types of PHI involved, mitigation steps, contact information)
- Coordination with affected organizations' breach-response procedures and, where applicable, OCR notification

The full breach incident-response procedure is defined inside the Connie BAA executed with each customer organization.

NOT CURRENTLY HIPAA-ELIGIBLE

The following are explicitly out of scope for HIPAA-eligible workflows on Connie today:

- WhatsApp messaging (no BAA available from the underlying provider)
 - Email channels (including Verify-via-email) — *pending Mailgun BAA audit and configuration review; eligibility under reassessment*
 - Third-party AI / chatbot add-ons not separately covered by an executed BAA
 - International voice and SMS traffic outside U.S. area codes
 - Public assets, public chat channels, or any feature explicitly noted as non-eligible in product documentation
-

QUESTIONS

To execute a BAA, designate accounts as HIPAA-eligible, or ask product-specific compliance questions, contact your Connie account representative or our Connie Care Team at **+1 (877) 606-4520** or **contact@connie.one**.

Disclaimer: This document is provided for informational purposes only and does not constitute legal advice. Customers are responsible for their own HIPAA compliance posture, including risk assessments, workforce training, and policies appropriate to their use of the platform.

Document Control Functional Prototype · Version 1.1 · Effective 2025-10-14 · NSS Internal & Stakeholders Only · Connie by Nevada Senior Services. Canonical copy maintained at connie.one/dataroom/legal/hipaa/Connie_HIPAA_Compliance_Statement_v1.1.pdf . Future versions supersede this version per [CHANGELOG.md](#) in the same dataroom path.